

GMX · SECURITY REVIEW

GMX
GLV JIT.

A security review of GLV JIT.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
GMX	GLV JIT	Guardian	August 1 – August 1, 2025	August 8, 2025

§ 00

Contents.

16 pages — overview, confidence ranking, scope, 7 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 7 findings	P. 08
§ 05	Disclaimer	P. 15
§ 06	About Guardian	P. 16

§ 01

Overview.

Guardian reviewed GLV JIT across a single review round. The final report includes 7 Informational findings.

AUDIT FIRM	METHODOLOGY
Guardian	Smart contract · Manual · Main Review
CLIENT	
GMX	
PROJECT	
GLV JIT	
PREPARED BY	
Guardian	
AUDIT WINDOW	
August 1 – August 1, 2025	
FINAL REPORT	
August 8, 2025	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	0	0	0	0	0
Informational	7	0	7	0	0
All severities	7	0	7	0	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed GLV JIT.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
NOTE-1	PnL To Pool Ratio Fluctuations	—	INFORMATIONAL	ACKNOWLEDGED	p. 8
NOTE-2	Markets Must Be Up To Date	—	INFORMATIONAL	ACKNOWLEDGED	p. 9
NOTE-3	Block Gas Limit Concern	—	INFORMATIONAL	ACKNOWLEDGED	p. 10
NOTE-4	Order Execution Affected In The From Market	—	INFORMATIONAL	ACKNOWLEDGED	p. 11
NOTE-5	JIT Action DoS	—	INFORMATIONAL	ACKNOWLEDGED	p. 12
NOTE-6	Actions Should Be Restricted To Expected Flows	—	INFORMATIONAL	ACKNOWLEDGED	p. 13
NOTE-7	JIT Used To Solve PnlToPoolRatio	—	INFORMATIONAL	ACKNOWLEDGED	p. 14

INFORMATIONAL **NOTE-1**

ACKNOWLEDGED

PnL To Pool Ratio Fluctuations

CATEGORY —
LOCATION Global
REVIEW Main Review

— DESCRIPTION

The GLV Shift action will remove a portion of the from market's pool liquidity and as a consequence the pnl to pool ratio of the from market will experience a stepwise increase.

Given that GLV Shifts use the underlying withdrawal execution code, this will be limited to the `pnlToPoolFactor` for withdrawals. As a result, the pnl to pool ratio of the from market can be a limiting factor on the availability of liquidity for the JIT action.

— RECOMMENDATION

Be sure to consider the current pnl to pool ratio of all markets which could supply liquidity in the off-chain calculation that decides which market to use.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL **NOTE-2**

ACKNOWLEDGED

Markets Must Be Up To Date

CATEGORY —
LOCATION Global
REVIEW Main Review

— DESCRIPTION

During the JIT action processing, it should be ensured that both markets are up to date with respect to borrowing/funding and impact distribution to perform accurate validations.

— RECOMMENDATION

Make sure that any pre-validations that are performed are considering an up to date view of both markets

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL **NOTE-3**

ACKNOWLEDGED

Block Gas Limit Concern

CATEGORY —
LOCATION Global
REVIEW Main Review

— DESCRIPTION

Combining the GLV Shift gas usage with the execution of an increase order will have a significant gas consumption and may pose issues for the block gas limit on Botanix, Arbitrum, or Avalanche.

— RECOMMENDATION

Be aware of this issue and be sure to benchmark the gas usage of increase orders that include swaps in the JIT action if that is supported.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL **NOTE-4**

ACKNOWLEDGED

Order Execution Affected In The From Market

CATEGORY —
LOCATION Global
REVIEW Main Review

— DESCRIPTION

JIT actions will draw liquidity away from the supplying market. This can have adverse affects on the operations of existing positions and orders in that market.

Notably, market orders which have yet to be executed and limit orders which rely on the backing pool amounts for either 1) swapping actions or 2) open interest reserves, will be affected.

Such orders will fail due to liquidity constraints leading to:

- Failed swap orders
- Failed increase orders by way of failed swaps on increase or lacking reserves
- Failed swaps on decrease orders

— RECOMMENDATION

Be aware of how this may affect the from market's existing positions and orders. Ideally the off-chain keeper can consider the pending orders in the from market and surmise how much liquidity should be left there, though this is non-trivial.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL **NOTE-5**

ACKNOWLEDGED

JIT Action DoS

CATEGORY	—
LOCATION	Global
REVIEW	Main Review

— DESCRIPTION

JIT actions may be unexpectedly DoS'd by atomic swaps through the gasless transactions router. A user may frontrun a JIT action (or such a swap may naturally happen right before a JIT action), that moves the imbalance in either the from or to market outside of the acceptable range for the GLV shift.

Such a swap may not need to be a significant size if either market is already close to the limits.

— RECOMMENDATION

This may be acceptable, even for networks with public mempools since there is no immediate gain for the malicious actor. However it is worth keeping in mind when assigning the thresholds for imbalance.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL **NOTE-6**

ACKNOWLEDGED

Actions Should Be Restricted To Expected Flows

CATEGORY —
LOCATION Global
REVIEW Main Review

— DESCRIPTION

JIT actions likely only need to be paired with increase position order types. As a result the GMX contracts should limit all other unexpected order types to reduce attack surface.

Furthermore, consider if increase orders which use swaps are expected, if not these orders should be restricted as well.

— RECOMMENDATION

Add validation to ensure that only the explicit increase order types that should be used are allowed. Consider if increase orders with swaps are expected to be used and validate these as well.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL NOTE-7

ACKNOWLEDGED

JIT Used To Solve PnlToPoolRatio

CATEGORY	—
LOCATION	Global
REVIEW	Main Review

DESCRIPTION

One of the main attack vectors introduced by the JIT action is the ability to “lead” liquidity to any target market within a GLV.

As a result of this, a user can affect the `pnlToPoolRatio` in the receiving market, causing a stepwise reduction in that market's `pnlToPoolRatio`.

This could be abused to allow a trader to realize more profit if they had their profits capped by the max pnl to pool factor for traders.

This could also be abused to allow LPs to exit if the `pnlToPoolRatio` is above the max pnl to pool factor for withdrawals.

This puts GLV holders in a bad position, causing them to always be used as the bail out for markets that have a high `pnlToPoolRatio`.

RECOMMENDATION

Validate that the market receiving the GLV Shift is not above the `pnlToPoolRatio` for withdrawals.

RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.